

Kavennesh Balachandar

+1 (786) 642-2837 | kavenneshsec@gmail.com | linkedin.com/in/kavenneshbv | kavennesh.com | github.com/Kavennesh | Hartford, CT

PROFESSIONAL SUMMARY

Cybersecurity engineer and **MS Cybersecurity** graduate (FIU, GPA **3.89/4.0**) with broad hands-on experience across **SOC & detection engineering, vulnerability management, network security, offensive security, and AWS cloud security**. Hardened **Cisco Secure Firewall 3100** across 3 enterprise sites reducing unauthorized access **40%**; built a full **ELK Stack** pipeline that cut **MTTR from 30 min to under 8 min (70%+)**; published peer-reviewed **DPI-based VPN detection** research at **90–95% accuracy**. **Active bug bounty researcher on HackerOne and Bugcrowd — 10 findings across 5 programs** (Jun–Jul 2026) including **Recorded Future** unauthenticated OAuth DCR, **Freshworks** CVSS 7.4 OAuth wildcard, **P2 PlanetHoster IDOR**, **P2 Confluence OAuth CSRF**, and independently-discovered path traversal. Holds **CompTIA Security+ (SY0-701)** — DoD 8570/8140 IAT II baseline — paired with **CRTA, eJPT, ICCA, CCSP-AWS, and CNSP**. Open to **SOC, detection engineering, vulnerability management, network security, AppSec, junior pentest, cloud security, and GRC** roles — F-1 OPT with **~3-year runway** via STEM extension, no sponsorship needed.

CORE COMPETENCIES

SOC & Detection Engineering

SIEM (ELK · Splunk · Sentinel)

Vulnerability Management

Threat Hunting & MITRE ATT&CK

Network Security (Cisco · TLS · IDS/IPS)

Offensive Security (CRTA · eJPT)

Bug Bounty Research (HackerOne · Bugcrowd)

AWS Cloud Security (IAM · GuardDuty · CloudTrail)

Incident Response

Python & Bash Automation

Active Directory Security

DoD 8570/8140 IAT II baseline

WORK EXPERIENCE

Florida International University

Aug 2025 – Apr 2026

Graduate Teaching Assistant — Database & SQL Server Administration

Miami, FL

- Coached **60+ graduate students** through SQL Server **role-based access controls**, privileged account management, and audit logging — directly mapping classroom labs to enterprise **identity governance** and access review workflows.
- Built **T-SQL automation** scripts and query-plan tuning walkthroughs that lifted lab performance metrics **20%** across two semesters.
- Guided students through SQL Server backup, recovery, and **high-availability strategies** (Always On Availability Groups, mirroring, SQL Server Agent) — reinforcing resilience and operational continuity principles.

Florida International University

Jan 2025 – Aug 2025

Graduate Teaching Assistant — Cybersecurity & Networking Labs

Miami, FL

- Delivered hands-on **SIEM and centralized-logging** labs covering ingestion, parsing, alert correlation, and detection-rule design — improving lab completion rates **22%** across two semesters of **50–60+ undergraduates**.
- Taught network detection labs with **Wireshark, Snort, and Suricata** — guiding students through live packet capture, signature tuning, and IDS rule creation for misconfigured SSH, packet injection, and port-scan scenarios.
- Authored **MITRE ATT&CK** mapping guides and walked students through controlled **OWASP Top 10** exploitation in DVWA (SQL injection, XSS, broken auth, CSRF) — pairing every attack technique with the defender control that detects or stops it.

Inter Deccan Solutions

Apr 2022 – Mar 2024

Network Security Analyst

Chennai, Tamil Nadu, India

- Configured and tuned **Cisco Secure Firewall 3100** appliances across **3 distributed enterprise sites** — zone-based policies, NAT, and ACLs reduced unauthorized access incidents **40%** within 6 weeks of deployment.
- Wrote **Python and Bash automation** for 12+ recurring Linux admin tasks (log rotation, user provisioning, patch verification, health monitoring) — saving **6–8 hrs/week** and improving **MTTR 35%**.
- Performed live network traffic analysis with **Wireshark, tcpdump, and Nmap** across enterprise networks; standardized **TLS 1.2/1.3** on all endpoints and decommissioned legacy SSL/TLS 1.0, sharply reducing exposure to **MitM** and protocol downgrade attacks.

PROJECTS & PUBLICATIONS

VPN Blocker — DPI-Based Detection & SIEM Integration PEER-REVIEWED PUBLICATION (2024)

- Published peer-reviewed research engineering a **Deep Packet Inspection** framework that detects unauthorized VPN tunnels (**OpenVPN, WireGuard, HTTPS-obfuscated**) at **90–95% accuracy** without decryption — using flow metadata, handshake timing, TLS certificate characteristics, and packet-size entropy.
- Integrated with **ELK Stack SIEM** for full event logging, automated firewall ACL updates, and **L1/L2/L3 RBAC** alert routing across security operations tiers.
- Quantified enterprise impact across a 10-week deployment: reduced **policy violations 50–60%** and cut **MTTR 30–40%** while preserving end-user privacy (no TLS decryption required).

Cyber Range Lab — Cloud-Deployed Penetration Testing Environment (Apr 2026)

- Architected an isolated **Docker-based** pentest lab on cloud VPS (**DVWA, OWASP Juice Shop**); Bash IaC automated full lab provisioning from **30+ min to under 5 min**.
- Executed full lifecycle attacks — **SQL injection** (manual + SQLMap), **Hydra** brute-force, XSS, command injection, auth bypass — achieving **95%+ exploitation success** across **OWASP Top 10**.

Automated Network Enumerator — Multi-Threaded Python Scanner (Mar–Apr 2026)

- Python utility combining **ICMP/ARP host detection**, **TCP SYN scanning**, and banner-grab service fingerprinting across **50+ host environments** with tunable thread-pool concurrency.
- JSON output integrates downstream into **PentestFlow** and **Metasploit** workspaces — cut manual enumeration **~40%** and lifted recon accuracy **~35%**.

PentestFlow — Modular Automated Penetration Testing Workflow (Jan–Feb 2026)

- Built a plug-in based **recon & enumeration pipeline** in Python wrapping **Nmap** with XML parsing into a structured schema; correlated services against a local **CVE** dataset and auto-generated HTML/Markdown reports.
- Validated across **50+ host environments** — reduced manual effort per phase **~40%** and total assessment time **~30%**.

Home Networking Lab — DPI VPN Detection & ELK SIEM Integration (May–Jul 2025)

- Built a full **ELK Stack** (Elasticsearch, Logstash, Kibana) detection pipeline from scratch — ingest parsing, indexing, dashboards, and Kibana alerting on statistically anomalous traffic.
- Cut mean response time **from 30 min to under 8 min (70%+ improvement)**; achieved **95% VPN classification accuracy** across 100+ tunnel sessions and reduced policy violations **60%** over a 10-week test.

VPN Monitoring & Detection System — Enterprise DPI Prototype (Jan–Mar 2024)

- Engineered prototype enterprise DPI engine flagging **unauthorized VPN tunneling** with flow metadata, TLS handshake timing, and packet-size entropy — foundation for the peer-reviewed VPN Blocker publication.
- Built **Python automation** and **Bash** tooling for live capture, classification, and alert generation; sustained **≥90% precision** across **OpenVPN/WireGuard/HTTPS-obfuscated** traffic without decryption.

EDUCATION

Master of Science — Cybersecurity Aug 2024 – Apr 2026

Florida International University · Miami, FL

GPA **3.89/4.0** · Coursework: Network Security, Digital Forensics & IR, Cyber Threat Intelligence, Secure Software Development, Cloud Security Architecture

Bachelor of Engineering — Computer Science & Engineering Nov 2020 – Mar 2024

Sri Krishna College of Engineering and Technology (Anna University) · India

Graduated with Distinction · 1st Place — Eraksha National Cybersecurity Competition (2023)

BUG BOUNTY & VULNERABILITY RESEARCH

Active researcher on **HackerOne** and **Bugcrowd** — **10 findings** across **5 programs (Jun–Jul 2026)**.

Recorded Future — Unauthenticated OAuth Dynamic Client Registration HIGH Bugcrowd

- Discovered **unauthenticated OAuth Dynamic Client Registration** on `mcp.recordedfuture.com` and `id.recordedfuture.com` accepting **attacker-controlled redirect_uri** values — enabling an attacker to register a malicious client and redirect victim **authorization codes** to an attacker endpoint.
- Submitted PoC with the full client-registration payload and recommended enforcing **authenticated DCR** with strict per-client `redirect_uri` allowlists and origin validation.

Freshworks — OAuth redirect_uri Wildcard Misconfiguration CVSS 7.4 HIGH HackerOne

- Identified **OAuth 2.0 redirect_uri wildcard misconfiguration** on Freshworks production endpoint allowing attacker-controlled subdomains to receive valid access tokens — rated **CVSS 7.4 High**.
- Demonstrated end-to-end **account-takeover chain** via token interception; submitted PoC with curl reproduction steps and recommended strict `redirect_uri` allowlist enforcement.

PlanetHoster — Unauthenticated IDOR, Customer Invoice Enumeration P2 / CVSS 7.5 HIGH Bugcrowd

- Discovered **unauthenticated IDOR** in billing endpoint enabling enumeration of **customer invoices** across the entire tenant base by incrementing a numeric ID parameter — rated **P2 / CVSS 7.5 High**.
- Built Python harness proving **PII exposure** at scale (names, addresses, line items) and recommended object-level **authorization checks** + per-tenant scoping on the affected route.

Mattermost — Confluence Plugin OAuth Account-Link CSRF P2 INDEPENDENT DISCOVERY Bugcrowd

- Reported missing **CSRF protection** on the Confluence plugin's **OAuth account-link** callback, allowing an attacker to silently bind a victim's Mattermost identity to an attacker-controlled Confluence account — rated **P2**, recognized as **Independent Discovery**.
- Authored full PoC with HTML attack page + recommended adding signed **state parameter** validation and SameSite=Strict cookies on the callback handler.

Mattermost — Jira Plugin IDOR + Admin Gate Bypass P3 INDEPENDENT DISCOVERY Bugcrowd

- Chained **IDOR** in the Jira plugin's subscription endpoint with an **admin gate bypass**, allowing a regular user to read/modify other users' Jira webhook subscriptions — rated **P3**, recognized as **Independent Discovery**.
- Submitted reproducer covering both primitives and recommended role-aware authorization plus tenant-scoped subscription IDs.

Mattermost — Server Burn-on-Read Reaction Metadata Leak P3 Bugcrowd

- Found that **burn-on-read messages** leaked **reaction metadata** via a side-channel endpoint after the message was destroyed, exposing who reacted and with what emoji — rated **P3**.
- Documented privacy-impact scenarios for sensitive channels and recommended deleting all dependent metadata atomically with the message itself.

Mattermost — Boards Guest Visibility Bypass + Admin Oracle P5 INFORMATIONAL INDEPENDENT DISCOVERY Bugcrowd

- Identified **guest visibility bypass** in Mattermost Boards where guest accounts could enumerate board membership and admin presence via a misconfigured introspection endpoint — rated **P5 Informational**, recognized as **Independent Discovery**.
- Provided reproducer and recommended restricting introspection to **same-board members** with explicit RBAC checks.

Mattermost — Playbooks Missing Channel Authorization P4 Bugcrowd

- Reported **missing channel-level authorization** on a Playbooks run-history endpoint, letting any authenticated user fetch runs tied to channels they had never joined — rated **P4**.
- Submitted PoC and recommended adding channel membership checks at the handler level before serving any playbook run metadata.

Lightspark — Sensitive Cryptographic Material in Logs (CWE-532) HIGH INDEPENDENT DISCOVERY HackerOne

- Discovered **CWE-532** exposure on Lightspark infrastructure leaking **sensitive cryptographic material** into application logs — rated **High**, recognized as **Independent Discovery**.
- Provided redacted reproduction trace and recommended structured log scrubbing for key/secret-shaped fields plus runtime sanitizer middleware.

Vercel / agent-skills — Arbitrary Local File Read via Path Traversal HIGH INDEPENDENT DISCOVERY HackerOne

- Identified **path-traversal** in Vercel agent-skills allowing **arbitrary local file read** from the host running the agent — rated **High**, recognized as **Independent Discovery**.
- Submitted PoC demonstrating read of /etc/passwd-equivalent host paths and recommended canonical-path normalization with an allowlisted skills root.

CERTIFICATIONS & AWARDS

CompTIA Security+ (SY0-701) — DoD 8570/8140 IAT II baseline	· CompTIA	Jun 2026
eJPT — Junior Penetration Tester	· INE Security	May 2026
Certified Red Team Analyst (CRTA)	· CyberWarfare Labs	May 2026
INE Certified Cloud Associate (ICCA)	· INE Security	May 2026
CCSP-AWS Merit — Certified Cloud Security Practitioner (AWS)	· The SecOps Group	Jan 2026
CNSP Merit — Certified Network Security Practitioner	· The SecOps Group	Oct 2025
Amazon AppSec CTF — Selected Participant (NAMER Region)	· Amazon	2025
1st Place — Eraksha National Cybersecurity Competition	· India	2023

TECHNICAL SKILLS

SOC & Detection: ELK Stack (Logstash, Elasticsearch, Kibana) · Splunk · Microsoft Sentinel · MITRE ATT&CK · Alert Engineering · Sigma Rules · Threat Hunting · Log Correlation

Network Security: Cisco Secure Firewall 3100 · pfSense · iptables/firewalld · Wireshark · tcpdump · Snort · Suricata · Nmap · TLS 1.2/1.3 · Zone-Based Segmentation

Offensive Security: Burp Suite · Metasploit · SQLMap · Hydra · Nmap NSE · CRTA-validated AD attack chains · OWASP Top 10 · eJPT methodology

Cloud & IAM: AWS IAM · CloudTrail · GuardDuty · Security Hub · VPC Flow Logs · CIS Benchmarks · Azure AD basics · CCSP-AWS-validated controls

Scripting & Automation: Python · Bash · PowerShell · T-SQL · REST APIs · JSON/YAML · Docker · Git

Frameworks & Compliance: NIST CSF · NIST 800-53 · MITRE ATT&CK · CIS Controls · OWASP Top 10 · SOC 2 · ISO 27001 · HIPAA basics · PCI DSS basics

Operating Systems: Kali Linux · Debian · Ubuntu · CentOS · Windows 10/11 · Windows Server 2019/2022 · Active Directory · macOS